VIRTUALLY YOURS

Uitleg bij de privacydocumenten

Inhoudsopgave

Hoofdpunten in deze uitleg **1**
Privacydocumenten **2**
AVG 2
Terminologie 2
Privacyverklaring **3**
Grondslagen 3
Doelen en bewaartermijnen 4
Privacybeleid 4
Samenwerken met derde partijen in het buitenland **4**
Binnen de EER 4
Buiten de EER 4
Verenigde Staten 5
Cookies **5**
Cookieverklaring 5
Soorten cookies 5
Cookiebanner 5
Verwerkersovereenkomst **5**
De overeenkomst 6
Opgave gegevensverwerking (bijlage 1) 6
Lijst van subverwerkers (bijlage 2) 6
Beveiligingsmaatregelen (bijlage 3) 7
Wanneer hoef je geen verwerkersovereenkomst te hebben? **8**
Je gaat geen persoonsgegevens verwerken 8
Er is sprake van intern beheer 8
Disclaimer **8**
Copyright **8**
Verwerkingsregister **9**

Hoofdpunten in deze uitleg

- Het is verplicht om een privacyverklaring te hebben. *(zie AVG)*
- Wanneer je gegevens verwerkt op basis van de grondslag “toestemming” moet je expliciet toestemming vragen aan de betrokkene en achteraf kunnen aantonen dat je toestemming hebt verkregen. *(zie Grondslagen)*
- Je moet de persoonsgegevens die je verwerkt niet langer bewaren dan strikt noodzakelijk is. Pas eventueel de bewaartermijnen in de Privacyverklaring aan. *(zie Doelen en bewaartermijnen)*
- Het is verplicht om een cookieverklaring en een cookiebanner te hebben als je een website hebt die privacygevoelige cookies gebruikt. *(zie AVG en Cookies)*
- Als er derde partijen zijn die voor jou gegevens verwerken, controleer dan of ze dat doen binnen of buiten de EER. Indien buiten de EER, controleer dan in welk land de organisatie de gegevens verwerkt en of het betreffende land een passend niveau van gegevensbescherming biedt. *(zie Samenwerken met derde partijen in het buitenland)*
- Het is verplicht om een verwerkersovereenkomst te gebruiken als je persoonsgegevens gaat verwerken in opdracht van je opdrachtgever, tenzij er sprake is van intern beheer *(zie AVG en Wanneer hoef je geen verwerkersovereenkomst te hebben?)*
- Op jouw juridische documenten rust auteursrecht en deze mag je niet zomaar verspreiden. *(zie Copyright)*

 © - Dit document is beschermd door auteursrecht - upr25v08

Privacydocumenten

Ik maak onderscheid tussen *privacydocumenten* en *opdrachtdocumenten*:

- De privacydocumenten hebben betrekking op de privacywetgeving, en dan in het bijzonder op de Algemene Verordening Gegevensbescherming (AVG). In dit geval gaat het om de privacyverklaring, de cookieverklaring, de disclaimer en de verwerkersovereenkomst.
- De opdrachtdocumenten zijn documenten die direct betrekking hebben op de opdracht zelf. Er zijn meerdere wetten relevant voor de opdrachtdocumenten, maar de Wet deregulering beoordeling arbeidsrelaties (DBA) en het Burgerlijk Wetboek zijn in het bijzonder van belang.

Overigens heeft de verwerkersovereenkomst (dat is de overeenkomst die verplicht is als je persoonsgegevens gaat verwerken in opdracht van je opdrachtgever) ook direct betrekking op de opdracht zelf, dus deze valt in feite onder beide categorieën in te delen. De verwerkersovereenkomst wordt vaak bij aanvang van de opdracht gelijktijdig met de OvO door partijen opgesteld en geaccordeerd. Je leest meer over de verwerkersovereenkomst in deze toelichting.

AVG

De Algemene Verordening Gegevensbescherming (AVG)[1], in het Engels bekend onder de naam General Data Protection Regulation (GDPR), is sinds 25 mei 2018 van toepassing in de hele Europese Unie (EU). De AVG geldt voor iedereen die persoonsgegevens verwerkt en stelt enkele documenten wettelijk verplicht:

- Privacyverklaring
- Cookieverklaring (als je een website hebt die privacygevoelige cookies gebruikt)
- Verwerkersovereenkomst (als je persoonsgegevens gaat verwerken voor opdrachtgevers)

Terminologie

Om goed te kunnen begrijpen waar de privacydocumenten over gaan, is het belangrijk om de terminologie enigszins te beheersen. Met name de verwerkersovereenkomst kent wat specifieke termen. Hieronder volgen enkele relevante definities uit artikel 4 van de AVG:

Artikel 4

Definities

Voor de toepassing van deze verordening wordt verstaan onder:

1) **„persoonsgegevens”**: alle informatie over een geïdentificeerde of identificeerbare natuurlijke persoon („de betrokkene”); als identificeerbaar wordt beschouwd een natuurlijke persoon die direct of indirect kan worden geïdentificeerd, met name aan de hand van een identificator zoals een naam, een identificatienummer, locatiegegevens, een online identificator of van een of meer elementen die kenmerkend zijn voor de fysieke, fysiologische, genetische, psychische, economische, culturele of sociale identiteit van die natuurlijke persoon;

2) **„verwerking”**: een bewerking of een geheel van bewerkingen met betrekking tot persoonsgegevens of een geheel van persoonsgegevens, al dan niet uitgevoerd via geautomatiseerde procedés, zoals het verzamelen, vastleggen, ordenen, structureren, opslaan, bijwerken of wijzigen, opvragen, raadplegen, gebruiken, verstrekken door middel van doorzending, verspreiden of op andere wijze ter beschikking stellen, aligneren of combineren, afschermen, wissen of vernietigen van gegevens;

Bij *“persoonsgegevens”* gaat het dus om informatie die ofwel direct over iemand gaat, ofwel indirect naar deze persoon te herleiden is. Bijvoorbeeld door meerdere persoonsgegevens met elkaar te combineren. Van bijvoorbeeld adresgegevens en namen is het voor iedereen wel duidelijk dat het om persoonsgegevens gaat. Maar soms ligt het iets minder voor de hand. Accountnamen op social media kunnen bijvoorbeeld soms ook herleidbaar zijn tot een individu en vallen dan ook onder persoonsgegevens.

Als we het hebben over “*de betrokkene*” dan gaat het dus om een geïdentificeerde of identificeerbare natuurlijke persoon. Een natuurlijk persoon is een mens van vlees en bloed, maar ook eenmanszaken vallen hieronder.

[1] https://eur-lex.europa.eu/eli/reg/2016/679/oj?locale=nl

 © - Dit document is beschermd door auteursrecht - upr25v08

Bij het werkwoord "*verwerken*" denk je misschien aan het actief dingen doen met de gegevens, maar het begrip moet dus ruim gezien worden. Volgens de AVG vallen in ieder geval de volgende handelingen onder het verwerken van persoonsgegevens: verzamelen, vastleggen, ordenen, structureren, opslaan, bijwerken of wijzigen, opvragen, raadplegen, gebruiken, doorzenden, verspreiden, beschikbaar stellen, samenbrengen, met elkaar in verband brengen, afschermen, wissen en vernietigen. Dus ook het simpelweg raadplegen van gegevens valt onder het begrip 'verwerken'.

7) **„verwerkingsverantwoordelijke"**: een natuurlijke persoon of rechtspersoon, een overheidsinstantie, een dienst of een ander orgaan die/dat, alleen of samen met anderen, het doel van en de middelen voor de verwerking van persoonsgegevens vaststelt; wanneer de doelstellingen van en de middelen voor deze verwerking in het Unierecht of het lidstatelijke recht worden vastgesteld, kan daarin worden bepaald wie de verwerkingsverantwoordelijke is of volgens welke criteria deze wordt aangewezen;

8) **„verwerker"**: een natuurlijke persoon of rechtspersoon, een overheidsinstantie, een dienst of een ander orgaan die/dat ten behoeve van de verwerkingsverantwoordelijke persoonsgegevens verwerkt;

9) **„ontvanger"**: een natuurlijke persoon of rechtspersoon, een overheidsinstantie, een dienst of een ander orgaan, al dan niet een derde, aan wie/waaraan de persoonsgegevens worden verstrekt. Overheidsinstanties die mogelijk persoonsgegevens ontvangen in het kader van een bijzonder onderzoek overeenkomstig het Unierecht of het lidstatelijke recht gelden echter niet als ontvangers; de verwerking van die gegevens door die overheidsinstanties strookt met de gegevensbeschermingsregels die op het betreffende verwerkingsdoel van toepassing zijn;

10) **„derde"**: een natuurlijke persoon of rechtspersoon, een overheidsinstantie, een dienst of een ander orgaan, niet zijnde de betrokkene, noch de verwerkingsverantwoordelijke, noch de verwerker, noch de personen die onder rechtstreeks gezag van de verwerkingsverantwoordelijke of de verwerker gemachtigd zijn om de persoonsgegevens te verwerken;

11) **„toestemming" van de betrokkene**: elke vrije, specifieke, geïnformeerde en ondubbelzinnige wilsuiting waarmee de betrokkene door middel van een verklaring of een ondubbelzinnige actieve handeling hem betreffende verwerking van persoonsgegevens aanvaardt;

In veel gevallen zal jouw opdrachtgever de "*verwerkingsverantwoordelijke*" zijn, en ben jij de "*verwerker*". Hier kun je meer over lezen bij de sectie over de verwerkersovereenkomst. De "*ontvanger*" is een partij aan wie je persoonsgegevens verstrekt, maar die (in tegenstelling tot een verwerker) verder niet in jouw opdracht iets doet met die gegevens. Bijvoorbeeld de Belastingdienst.

Privacyverklaring

Je bent dus wettelijk verplicht om een privacyverklaring te hebben waarin je uitlegt welke gegevens je verzamelt, waarom je dat doet, hoe lang je ze bewaart, en met wie je ze deelt. Je kunt deze privacyverklaring op je website plaatsen. Vaak wordt deze geplaatst in de footer van de website, eventueel tezamen met je cookieverklaring en/of algemene voorwaarden.

Grondslagen

Je mag persoonsgegevens alleen maar verwerken op basis van wettelijk vastgestelde grondslagen. In je privacyverklaring staat in artikel "*Op basis van welke grondslagen verwerk ik persoonsgegevens?*" opgenomen welke grondslagen op jou van toepassing zijn. Voor een online dienstverlener zullen doorgaans de volgende grondslagen relevant zijn:

I. Ik heb toestemming gekregen;
II. Ik heb de gegevens nodig om een overeenkomst uit te voeren;
III. Ik ben wettelijk verplicht om deze gegevens te verwerken;
IV. Ik heb de gegevens nodig om mijn gerechtvaardigde belang te behartigen.

Wanneer je gegevens verwerkt op basis van de grondslag "toestemming", moet je (achteraf) kunnen aantonen dat je de expliciete toestemming voor de verwerking van de betreffende persoon hebt ontvangen. Je moet kunnen aantonen wie toestemming heeft gegeven, wanneer de toestemming is gegeven, waarvoor er toestemming is gegeven en hoe de toestemming is gevraagd.

 © - Dit document is beschermd door auteursrecht - upr25v08

Als je bijvoorbeeld persoonsgegevens gaat verwerken om een nieuwsbrief te versturen, dan moet je in veel gevallen expliciet toestemming krijgen daarvoor, bijvoorbeeld door middel van een opt-in op je website. Controleer in dat geval of het opt-in formulier en/of de e-mailmarketingtool die je gebruikt de toestemming goed registreert, bijvoorbeeld door middel van een opgeslagen logregel met datum, IP-adres, formulier-ID, en inhoud van de toestemmingsvraag.

Doelen en bewaartermijnen
In de privacyverklaring staan bij "*Waarvoor gebruik ik jouw gegevens?*" de verschillende doelen opgesomd waarvoor je persoonsgegevens verwerkt. Voor elk doel is het verplicht om te specificeren op basis van welke grondslag je dat doet, hoe lang je de gegevens bewaart en waarom je voor die bewaartermijn hebt gekozen. Hou er rekening mee dat je alleen gegevens mag verwerken die je echt nodig hebt. Je mag dus geen gegevens verzamelen, als je daar geen goede reden voor hebt.

Bij veel doelen staat nu standaard in blauwgekleurde letters een voorbeeld bewaartermijn en onderbouwing opgenomen (bijvoorbeeld 12 maanden om ...). Het uitgangspunt is dat je persoonsgegevens niet langer dan noodzakelijk mag bewaren. Wat noodzakelijk is, hangt af van de situatie. Vandaar dat je zelf moet vaststellen wat in jouw situatie passend is. Er is helaas geen formule of algemene standaard voor het vaststellen van bewaartermijnen.

Bij het vaststellen van een bewaartermijn kun je rekening houden met je eventuele wens om de betrokkene op een later moment nog eens te benaderen. Als je bijvoorbeeld een offerte hebt gestuurd die niet is geaccepteerd, dan is het te rechtvaardigen dat je na enkele maanden nog eens contact opneemt met de betreffende persoon om te kijken of er mogelijk alsnog interesse is in je diensten en/of om een nieuw aanbod te doen. Ga dus voor jezelf na wat je eventueel nog met de persoonsgegevens zou willen gaan doen op een later moment, wanneer je dit zou willen doen, en of dit te rechtvaardigen is. Pas daarop voor het betreffende doel de bewaartermijn aan in de privacyverklaring en neem de onderbouwing op.

Privacybeleid
Let op: Een *privacybeleid* is iets anders dan een *privacyverklaring*. Iedere organisatie is verplicht om met een privacyverklaring mensen heldere informatie te geven over de persoonsgegevens die de organisatie verwerkt en voor welke doelen dat gebeurt. Een privacyverklaring is dus gericht aan o.a. klanten en websitebezoekers. Een privacybeleid is daarentegen een doorgaans intern document, waarmee een organisatie aan een verantwoordingsplicht voldoet. Een privacybeleid is alleen verplicht als dat in verhouding staat tot de verwerkingsactiviteiten van de organisatie, bijvoorbeeld als er op grote schaal bijzondere persoonsgegevens worden verwerkt. Denk hierbij aan ziekenhuizen en gemeenten.

Samenwerken met derde partijen in het buitenland

In je privacyverklaring staat opgenomen dat je je ervan verzekert dat eventuele derde partijen in het buitenland waar jij mee samenwerkt, voldoende zorgvuldig omgaan met de veiligheid van de persoonsgegevens. Persoonsgegevens doorgeven vanuit Nederland naar het buitenland mag alleen als dat land voldoende bescherming biedt. De bescherming van persoonsgegevens is helaas niet in alle landen hetzelfde geregeld.

Binnen de EER
Binnen de Europese Economische Ruimte (EER) is het niveau van gegevensbescherming wél gelijk. Dat komt omdat alle EER-landen zich moeten houden aan de AVG. De EER is daarom één rechtsgebied bij de bescherming van persoonsgegevens, waarbinnen dezelfde regels gelden. Bij de EER horen alle EU-landen plus Liechtenstein, Noorwegen en IJsland. Je hoeft voor de doorgifte naar landen binnen de EER dus geen aanvullende maatregelen te nemen.

Buiten de EER
Het kan ook zijn dat je gegevens deelt met een partij in een ander land, buiten de EER. Denk hierbij bijvoorbeeld aan hosting, cloudopslag of bepaalde software, of partijen zoals Google. Voor doorgifte van gegevens naar een land buiten de EER (zogenaamde derde landen) gelden andere regels dan voor doorgifte naar een land binnen de EER. Voor sommige derde landen heeft de Europese Commissie vastgesteld dat hun nationale wetgeving een passend niveau van gegevensbescherming biedt. Het gaat onder andere om landen als Andorra, Argentinië, Israël, Japan, Nieuw-Zeeland. Uruguay, Verenigd Koninkrijk, Zwitserland en Zuid-Korea. Voor doorgifte naar deze landen hoef je dus geen aanvullende maatregelen te treffen. Een volledige lijst van de landen is te vinden op de website van de Autoriteit

 © - Dit document is beschermd door auteursrecht - upr25v08

Persoonsgegevens[2]. Daar kun je ook meer lezen over wat je moet doen als je gegevens doorgeeft naar landen die *niet* op deze lijst staan.

Verenigde Staten
Ook voor doorgifte naar de Verenigde Staten (VS) gelden aparte regels. Hoe dit werkt, hangt ervan af of die organisatie wel of niet meedoet aan het Data Privacy Framework. Hoe je dit kunt controleren en meer uitleg hierover kun je lezen op de website van de Autoriteit Persoonsgegevens[3].

Cookies

Cookies zijn kleine tekstbestanden die bij het eerste bezoek aan een website worden opgeslagen op het apparaat van een gebruiker, zoals je computer, tablet of telefoon.

Cookieverklaring
Bij gebruik van (privacygevoelige) cookies op je website is het wettelijk verplicht om een cookieverklaring te hebben, waarin je uitlegt welke cookies je gebruikt, wat hun functie is, en hoe bezoekers ze kunnen uitschakelen. Je kunt deze cookieverklaring op je website plaatsen. Vaak wordt deze geplaatst in de footer van de website, tezamen met de privacyverklaring en eventueel tezamen met je algemene voorwaarden.

Soorten cookies
In jouw cookieverklaring (indien van toepassing) staan de verschillende cookies beschreven, ook als je hebt aangegeven deze cookies niet te gebruiken. In dat laatste geval is de omschrijving van het betreffende type cookie wel een stukje korter, en staat *niet* opgenomen in de alinea dat je het betreffende type cookie gebruikt. Ze staan toch opgenomen in de verklaring, deels omdat dit ook informatief kan zijn voor je websitebezoeker en deels zodat je relatief eenvoudig het gebruik van dit type cookie later kunt toevoegen als je op een bepaald moment alsnog het type cookie gaat gebruiken. Je mag de uitleg over de niet door jou gebruikte cookies gerust verwijderen uit de cookieverklaring.

Cookiebanner
Zorg ook dat je cookiebanner op orde is. Deze moet ook verplicht aan bepaalde voorwaarden voldoen. De Autoriteit Persoonsgegevens geeft de volgende vuistregels:

- Geef informatie over het doel
- Zet vinkjes niet automatisch aan
- Gebruik duidelijke tekst
- Zet verschillende keuzes op één laag
- Verberg bepaalde keuzes niet
- Laat iemand niet extra klikken
- Gebruik geen onopvallende link in de tekst
- Wees helder over het intrekken van toestemming
- Verwar toestemming niet met gerechtvaardigd belang

Soms kan het ook handig zijn een tool op je website te implementeren die automatisch de door jou gebruikte cookies in kaart brengt en inzichtelijk maakt voor je websitebezoekers, zoals bijvoorbeeld Cookiebot. Een dergelijke tool kan vaak ook zorgen voor een cookiebanner die aan de eisen voldoet. Mocht dit niet je eigen expertise zijn, dan kun je hier eventueel advies over inwinnen bij je/een webdesigner of technisch VA.

Meer informatie over de privacyverklaring, cookieverklaring en cookiebanner is te vinden op de website van de Autoriteit Persoonsgegevens[4].

Verwerkersovereenkomst

Een verwerkersovereenkomst is in principe wettelijk verplicht als je in opdracht van je opdrachtgever persoonsgegevens gaat verwerken, en jouw opdrachtgever bepaalt het doel en de essentiële middelen voor de verwerking.

[2] https://www.autoriteitpersoonsgegevens.nl/themas/internationaal/doorgifte-binnen-en-buiten-de-eer/doorgifte-persoonsgegevens-buiten-de-eer
[3] https://www.autoriteitpersoonsgegevens.nl/themas/internationaal/doorgifte-binnen-en-buiten-de-eer/doorgifte-persoonsgegevens-naar-de-vs
[4] https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg

 © - Dit document is beschermd door auteursrecht - upr25v08

Wanneer je voor een opdrachtgever persoonsgegevens gaat verwerken, en jouw opdrachtgever bepaalt het doel en de essentiële middelen voor de verwerking, dan ben jij een 'verwerker' en is jouw opdrachtgever de 'verwerkingsverantwoordelijke'. Je mag als verwerker wel zelfstandig beslissingen nemen over 'niet-essentiële middelen', zoals bijvoorbeeld welk type hard- of software je gebruikt.

De overeenkomst
In een verwerkersovereenkomst leg je o.a. vast welke persoonsgegevens je gaat verwerken in opdracht van je opdrachtgever, en met welke doelen je deze gegevens gaat verwerken. Ook leg je hierin vast hoe de gegevens beveiligd worden en wat je zult doen als er zich een datalek voordoet. Daarnaast moet de verwerkersovereenkomst nog andere onderwerpen verplicht behandelen, zoals een geheimhoudingsplicht, subverwerkers, privacyrechten en audits.

Meestal is de VA de 'verwerker' en de opdrachtgever de 'verwerkingsverantwoordelijke'. Mocht je zelf iemand op een zeker moment inschakelen die in jouw opdracht persoonsgegevens gaat verwerken, dan kun je gewoon dezelfde overeenkomst gebruiken, alleen ben jij dan de verwerkingsverantwoordelijke en is degene die voor jou werkt de verwerker. Dit kun je dan aanpassen op de eerste pagina.

Let op dat je volgens de wet samen met je opdrachtgever verantwoordelijk bent voor het gebruiken van een goede verwerkersovereenkomst, ondanks het feit dat je opdrachtgever 'verwerkingsverantwoordelijke' wordt genoemd. Beide partijen zijn dus aansprakelijk als zo een overeenkomst ontbreekt. Het maakt hierbij niet uit wie de overeenkomst aanlevert. Je kunt dus ook gebruik maken van een verwerkersovereenkomst van je opdrachtgever. Controleer dan wel goed of de overeenkomst die de opdrachtgever aanlevert aan alle eisen voldoet.

Een verwerkersovereenkomst sluit af je vóórdat je begint met het verwerken van persoonsgegevens. Meestal is dit dus bij aanvang van de opdracht (gelijktijdig met de overeenkomst van opdracht). De bijlagen 1 en 3 vul je dan samen met je opdrachtgever in. Het gebruik van bijlage 2 is optioneel. Deze kun je desgewenst gebruiken wanneer je gebruik maakt van subverwerkers.

Opgave gegevensverwerking (bijlage 1)
In artikel 28 lid 3 van de AVG staat vermeld welke kenmerken van de verwerking je precies moet omschrijven in de verwerkersovereenkomst:

> 3. De verwerking door een verwerker wordt geregeld in een overeenkomst of andere rechtshandeling krachtens het Unierecht of het lidstatelijke recht die de verwerker ten aanzien van de verwerkingsverantwoordelijke bindt, en waarin het onderwerp en de duur van de verwerking, de aard en het doel van de verwerking, het soort persoonsgegevens en de categorieën van betrokkenen, en de rechten en verplichtingen van de verwerkingsverantwoordelijke worden omschreven. Die overeenkomst of andere rechtshandeling bepaalt met name dat de verwerker:

Je moet dus het onderwerp en de duur van de verwerking, de aard en het doel van de verwerking, het soort persoonsgegevens en de categorieën van betrokkenen specificeren. Hier dient bijlage 1 voor.

Lijst van subverwerkers (bijlage 2)
Het woord "subverwerker" komt niet als zodanig voor in de AVG, maar het is de term die doorgaans wordt gebruikt in overeenkomsten. Het gaat hier dan om een situatie waarbij een verwerker een andere verwerker heeft ingeschakeld. Die andere verwerker is dan de subverwerker.

In artikel 28 lid 2 van de AVG staat opgenomen dat het verplicht is om eerst schriftelijk toestemming van de verwerkingsverantwoordelijke te ontvangen voordat een subverwerker ingeschakeld mag worden:

> 2. De verwerker neemt geen andere verwerker in dienst zonder voorafgaande specifieke of algemene schriftelijke toestemming van de verwerkingsverantwoordelijke. In het geval van algemene schriftelijke toestemming licht de verwerker de verwerkingsverantwoordelijke in over beoogde veranderingen inzake de toevoeging of vervanging van andere verwerkers, waarbij de verwerkingsverantwoordelijke de mogelijkheid wordt geboden tegen deze veranderingen bezwaar te maken.

Er staat niet specifiek aangegeven dat deze schriftelijke toestemming verwerkt dient te worden in de verwerkersovereenkomst, dus dat mag ook op een andere wijze. Bijlage 2 is daarom optioneel en kan desgewenst

 © - Dit document is beschermd door auteursrecht - upr25v08

weggehaald worden. Indien je besluit bijlage 2 weg te halen, vergeet dan niet ook de inhoudsopgave aan te passen, en de verwijzing naar bijlage 2 weg te halen in artikel 4 en in het lijstje met bijlagen onderaan de overeenkomst.

Het is ook toegestaan om te werken met een “algemene” schriftelijke toestemming. In dat geval is het de verwerker toegestaan om subverwerkers in te schakelen, tenzij de verwerkingsverantwoordelijke hier bezwaar tegen heeft. Er hoeft dan dus niet voor elke subverwerker apart toestemming verkregen te worden. De verwerker moet er wel bijtijds melding van maken zodat de verwerkingsverantwoordelijke voldoende tijd heeft om bezwaar te maken.

Ik krijg soms de vraag of het artikel over subverwerkers weggehaald mag worden. Helaas kan dit niet om meerdere redenen:

- Er staat in de AVG opgenomen dat de verwerkersovereenkomst bepaalt dat aan de voorwaarden rondom het in dienst nemen van een andere verwerker wordt voldaan. Dit is dus een verplicht onderdeel.
- Het is altijd mogelijk dat je op een later moment alsnog een subverwerker gaat inschakelen en dan wil je natuurlijk wel dat dat al is gedekt in de overeenkomst.
- Je schakelt sneller een subverwerker in dan je denkt! Zeker ook als je gebruik maakt van online tools en diensten. Denk hierbij aan cloudopslag, e-maildienstverleners, nieuwsbriefsoftware, boekhoudsoftware, etc. Dit zijn subverwerkers als jij deze tools aanschaft of inschakelt. Als de verwerkingsverantwoordelijke deze tools heeft aangeschaft en jij werkt erin, dan zijn het geen subverwerkers van jou, maar verwerkers van de verwerkingsverantwoordelijke.

Beveiligingsmaatregelen (bijlage 3)
In artikel 32 van de AVG staat dat het verplicht is om passende beveiligingsmaatregelen te treffen:

Artikel 32

Beveiliging van de verwerking

1. Rekening houdend met de stand van de techniek, de uitvoeringskosten, alsook met de aard, de omvang, de context en de verwerkingsdoeleinden en de qua waarschijnlijkheid en ernst uiteenlopende risico's voor de rechten en vrijheden van personen, treffen de verwerkingsverantwoordelijke en de verwerker passende technische en organisatorische maatregelen om een op het risico afgestemd beveiligingsniveau te waarborgen, die, waar passend, onder meer het volgende omvatten:

a) de pseudonimisering en versleuteling van persoonsgegevens;

b) het vermogen om op permanente basis de vertrouwelijkheid, integriteit, beschikbaarheid en veerkracht van de verwerkingssystemen en diensten te garanderen;

c) het vermogen om bij een fysiek of technisch incident de beschikbaarheid van en de toegang tot de persoonsgegevens tijdig te herstellen;

d) een procedure voor het op gezette tijdstippen testen, beoordelen en evalueren van de doeltreffendheid van de technische en organisatorische maatregelen ter beveiliging van de verwerking.

2. Bij de beoordeling van het passende beveiligingsniveau wordt met name rekening gehouden met de verwerkingsrisico's, vooral als gevolg van de vernietiging, het verlies, de wijziging of de ongeoorloofde verstrekking van of ongeoorloofde toegang tot doorgezonden, opgeslagen of anderszins verwerkte gegevens, hetzij per ongeluk hetzij onrechtmatig.

In bijlage 3 van de verwerkersovereenkomst kunnen jullie vastleggen welke beveiligingsmaatregelen jullie nemen. Daarbij moeten jullie zelf inschatten wat passende maatregelen zijn voor de gegevens die verwerkt gaan worden, op basis van de verwerkingsrisico’s. De in bijlage 3 opgesomde technische en organisatorische maatregelen dienen slechts als suggestie en deze mogen verwijderd worden.

 © - Dit document is beschermd door auteursrecht - upr25v08

Wanneer hoef je geen verwerkersovereenkomst te hebben?

In bepaalde gevallen is het niet nodig om een verwerkersovereenkomst met je opdrachtgever af te sluiten.

Je gaat geen persoonsgegevens verwerken
Als je geen persoonsgegevens gaat verwerken in opdracht van je opdrachtgevers, hoef je geen verwerkersovereenkomst te hebben. Veel VA's verwerken echter wél persoonsgegevens voor klanten. Je verwerkt bijvoorbeeld persoonsgegevens als je de inbox van je opdrachtgever beheert (of zelfs alleen maar raadpleegt), als je contact hebt met mensen via het social mediakanaal van je opdrachtgever, als je facturen opstelt voor je opdrachtgever, etc.

Er is sprake van intern beheer
Daarnaast hoef je ook geen verwerkersovereenkomst te hebben als je onder rechtstreeks gezag staat van de verwerkingsverantwoordelijke. Er is dan sprake van intern beheer.

De overheid zegt hierover het volgende:

> "*Er is alleen sprake van verwerkerschap als de verwerker niet aan het rechtstreekse gezag van de verwerkingsverantwoordelijke is onderworpen. Wanneer u ondergeschikt bent aan de verwerkingsverantwoordelijke of er anderszins sprake is van een hiërarchische verhouding (u bent bijvoorbeeld medewerker, gedetacheerd bij de verwerkingsverantwoordelijke of een ZZP'er die werkt onder de instructies van uw opdrachtgever), dan is er geen sprake van verwerkerschap.*" [5]

En daarnaast geeft de Autoriteit Persoonsgegevens nog de volgende toelichting:

> "*Als u een verwerker bent, moet u zich volledig houden aan de instructies van de organisatie die u de opdracht heeft gegeven om persoonsgegevens te verwerken. Maar dat is niet hetzelfde als rechtstreeks onderworpen zijn aan het gezag van de verwerkingsverantwoordelijke.*" [6]

Het is niet altijd even duidelijk of er sprake is van intern beheer of niet. Je zult zelf moeten beoordelen of je onder het gezag of in een hiërarchische verhouding staat tot je opdrachtgever. Bij intern beheer moet je bijvoorbeeld volledig in de (beveiligde) systemen van je opdrachtgever werken en je mag niet lokaal persoonsgegevens op je eigen laptop opslaan. Als er sprake is van intern beheer hoef je geen verwerkersovereenkomst te hebben. Zorg dan wel dat je alsnog bepaalde afspraken rondom de verwerking goed vastlegt, waaronder afspraken over geheimhouding.

Let op! Hoewel "gezag" met betrekking tot de verwerking van persoonsgegevens niet hetzelfde is als "gezag" met betrekking tot je opdracht, kan het geen kwaad om er rekening mee te houden dat een gezagsverhouding an sich ook gevolgen kan hebben voor eventuele schijnzelfstandigheid. Gezag is een belangrijk criterium bij het bepalen of er sprake is van een arbeidsovereenkomst (in plaats van een opdracht als zzp'er).

Disclaimer

Een disclaimer is een eenzijdige verklaring en heeft in principe weinig juridische waarde, maar kan voor je websitebezoeker wel zinvol zijn. Het is eigenlijk een document dat tegen je websitebezoekers zegt: "*Als je mijn website bezoekt, hou er dan rekening mee dat … geldt voor de inhoud van mijn website*". Omdat de juridische waarde van de disclaimer beperkt is, kun je hier ook zonder problemen zelf nog dingen aan toevoegen die voor jouw websitebezoekers belangrijk kunnen zijn of besluiten geen gebruik te maken van een disclaimer. Voor een eenvoudige website is een disclaimer doorgaans niet heel zinvol.

Copyright

De juridische documenten en toelichtingen die je hebt ontvangen zijn opgesteld door Risha Smeding van Virtually Yours. Het auteursrecht op deze documenten ligt dan ook bij Virtually Yours. Je mag deze documenten uitsluitend gebruiken voor eigen gebruik. Het is niet toegestaan om de documenten zomaar te verspreiden, te kopiëren, te verkopen of wijzigingen aan te (laten) brengen, tenzij daar afspraken over zijn gemaakt. Uiteraard mag je wel altijd aanpassingen doen die nodig zijn om de documenten goed te kunnen gebruiken.

[5] Handleiding Algemene verordening gegevensbescherming versie 2.0, 2023
[6] https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg/avg-algemeen/verantwoordelijke-en-verwerker

Verwerkingsregister

Let op, het verwerkingsregister is géén onderdeel van het starterspakket of het privacypakket. Helaas kan ik daarom vragen over het verwerkingsregister niet (kosteloos) beantwoorden.

Een verwerkingsregister is een document waarin je voor jezelf bijhoudt welke persoonsgegevens je verwerkt. Dit is een intern document, dus je plaatst dit niet op je website en stuurt dit niet naar je klanten toe.

Als je persoonsgegevens niet slechts incidenteel verwerkt, ben je volgens de AVG verplicht om een verwerkingsregister bij te houden. In de praktijk zijn verwerkingen niet vaak incidenteel en zul je dus een verwerkingsregister nodig hebben.

Voor de verwerkingen van persoonsgegevens die je doet voor je eigen onderneming (dus niet in opdracht van een opdrachtgever), ben jij de verwerkingsverantwoordelijke en dien je een verwerkingsregister bij te houden. Als je in opdracht van je opdrachtgever gegevens verwerkt ben je een verwerker. Ook dan heb je een verwerkingsregister nodig.

Je mag zelf weten hoe je het register opstelt. Je kunt het register bijvoorbeeld in een spreadsheet of een tekstbestand maken. Op internet kun je ook veel voorbeelden vinden. Je kunt bij het invullen van het register onder andere gebruikmaken van de informatie in je privacyverklaring.

Op de website van de Autoriteit Persoonsgegevens[7] kun je meer informatie vinden. Hieronder volgen enkele screenshots die afkomstig zijn van de website van de Autoriteit Persoonsgegevens.

Een verwerkingsregister bijhouden

In het verwerkingsregister staat informatie over de persoonsgegevens die u verwerkt. Het opstellen van een verwerkingsregister (AVG: 'register van verwerkingsactiviteiten') is onder de AVG vaak een verplichte maatregel. Of u een verwerkingsregister moet opstellen, hangt af van de omvang van uw organisatie en het type gegevens dat u verwerkt.

Heeft uw organisatie meer dan 250 medewerkers? Dan bent u sowieso verplicht om een verwerkingsregister bij te houden.

Heeft uw organisatie minder dan 250 medewerkers? Dan moet u een verwerkingsregister opstellen als een of meer van deze situaties op u van toepassing zijn:

- De verwerking van persoonsgegevens is niet incidenteel. Let op: In de praktijk zijn verwerkingen zelden incidenteel. Denk bijvoorbeeld aan de persoonsgegevens van medewerkers die u verwerkt. Of van uw klanten, cliënten, patiënten of inwoners.
- U verwerkt persoonsgegevens die een hoog risico inhouden voor de rechten en vrijheden van de personen van wie u persoonsgegevens verwerkt.
- U verwerkt persoonsgegevens die vallen onder de categorie bijzondere persoonsgegevens . Bijvoorbeeld gegevens over gezondheid, godsdienst of politieke voorkeur.

U mag zelf weten hoe u het register opstelt.

Wel schrijft de AVG voor welke informatie u als verwerkingsverantwoordelijke of verwerker in het verwerkingsregister moet zetten.

[7] https://www.autoriteitpersoonsgegevens.nl/themas/basis-avg/avg-algemeen/verantwoordingsplicht

 © - Dit document is beschermd door auteursrecht - upr25v08

Verwerkingsregister van verwerkingsverantwoordelijke

De AVG schrijft voor dat u als verwerkingsverantwoordelijke deze informatie in het register moet opnemen:

Naam en contactgegevens

De naam en contactgegevens van:

- uw organisatie of de vertegenwoordiger van uw organisatie;
- eventuele andere organisaties met wie u gezamenlijk de doelen van en middelen voor de verwerking heeft vastgesteld (gezamenlijke verantwoordelijkheid);
- de functionaris gegevensbescherming (FG), als u die heeft aangesteld;
- eventuele internationale organisaties waarmee u persoonsgegevens deelt.

Doeleinden

De doelen waarvoor u de persoonsgegevens verwerkt. Bijvoorbeeld de werving en selectie van personeel, het bezorgen van producten of direct marketing.

Tip: Het is aan te raden om hierbij ook de grondslag te vermelden voor elk van uw verwerkingen. U bent dit niet verplicht volgens de AVG, maar het kan wel helpen om aan uw verantwoordingsplicht te voldoen.

Betrokkenen

Een beschrijving van de categorieën van personen van wie u gegevens verwerkt. Bijvoorbeeld uitkeringsgerechtigden, klanten of patiënten.

Persoonsgegevens

Een beschrijving van de categorieën van persoonsgegevens. Zoals het burgerservicenummer (BSN), NAW-gegevens, telefoonnummers, camerabeelden of IP-adressen.

Bewaartermijn

De datum waarop u de gegevens moet wissen (als dat bekend is).

Ontvangers

De categorieën van ontvangers waaraan u persoonsgegevens verstrekt.

Buiten EER

Deelt u de gegevens met een land of internationale organisatie buiten de EER? Dan moet u dit aangeven in het verwerkingsregister.

Beveiliging

Een algemene beschrijving van de technische en organisatorische maatregelen die u heeft genomen om de persoonsgegevens die u verwerkt te beveiligen.

De AVG schrijft voor dat je de volgende informatie moet opnemen:

- Naam en contactgegevens
- Doeleinden
- Betrokkenen
- Persoonsgegevens
- Bewaartermijn
- Ontvangers
- Buiten EER
- Beveiliging

 © - Dit document is beschermd door auteursrecht - upr25v08

Ook als je als verwerker persoonsgegevens verwerkt in opdracht van je opdrachtgever heb je een verwerkingsregister nodig.

Verwerkingsregister van verwerker

Verwerkt u in opdracht van een verwerkingsverantwoordelijke persoonsgegevens? Bijvoorbeeld als administratiekantoor of online dienst voor gegevensopslag? Dan moet deze informatie in uw verwerkingsregister staan:

Naam en contactgegevens

De naam en contactgegevens van:

- uw organisatie, of de vertegenwoordiger van uw organisatie, of de verwerkingsverantwoordelijke;
- de functionaris gegevensbescherming (FG), als u die heeft aangesteld.

Verwerkingen

Een beschrijving van de categorieën van verwerkingen die u in opdracht van iedere verwerkingsverantwoordelijke uitvoert.

Buiten EER

Deelt u de gegevens met een land of internationale organisatie buiten de EER? Dan moet u dit aangeven in het verwerkingsregister.

Beveiliging

Een algemene beschrijving van de technische en organisatorische maatregelen die u heeft genomen om de persoonsgegevens die u verwerkt te beveiligen.

 © - Dit document is beschermd door auteursrecht - upr25v08